

Matriz de Evaluación PRAGMATIC Completa

Esta matriz ofrece un ejemplo de cómo evaluar, bajo PRAGMATIC, un conjunto de métricas representativas de cada pilar GCI. Puede ampliarse con todas las métricas del catálogo.

1. Escala de evaluación

Para cada criterio PRAGMATIC se usará una escala de 1 a 5:

- 1: Muy pobre
- 2: Pobre
- 3: Aceptable
- 4: Bueno
- 5: Excelente

Opcionalmente, puede calcularse una puntuación total o media para comparar métricas, como sugieren las guías de metamétricas de seguridad.[web:47][web:50][web:55]

2. Tabla ejemplo por métrica

2.1. Métrica M2.1.3 – Tiempo medio de detección (MTTD) de incidentes significativos

Criterio PRAGMATIC	Pregunta guía	Puntuación (1-5)	Comentarios
P – Predictivo	¿Permite anticipar problemas futuros (p. ej. saturación de capacidades SOC)?	4	Tendencias de MTTD indican eficacia de detección y posibles degradaciones.
R – Relevante	¿Es clave para los objetivos de resiliencia y continuidad?	5	Directamente relacionado con impacto de incidentes y resiliencia.
A – Accionable	¿Sugiere acciones concretas?	4	Puede llevar a invertir en detección, tuning de reglas, refuerzo de equipo.
G – Genuino	¿Es difícil de manipular sin ser detectado?	3	Riesgo de sub-declarar incidentes; mitigable con criterios de clasificación.
M – Significativo	¿Es comprensible para dirección?	4	Fácil de explicar (“tardamos X horas en darnos cuenta de un ataque”).
A – Preciso	¿Los datos son fiables y consistentes?	3	Depende de la calidad de registros y correlación de eventos.
T – Oportuno	¿Está disponible a tiempo para decisiones?	4	Puede actualizarse mensualmente o en tiempo real.
I – Independiente	¿No depende de una sola persona/fuente?	4	Se deriva de sistemas, no de opiniones individuales.
C – Rentable	¿Coste de medición razonable?	3	Requiere SOC / SIEM mínimamente maduros.

Puntuación media aproximada: 3,8 – Métrica recomendable.

2.2. Métrica M4.1.1 – % de empleados que completan formación anual en ciberseguridad

Criterio PRAGMATIC	Pregunta guía	Puntuación	Comentarios
P – Predictivo	¿Predice futuros incidentes humanos?	3	Correlación indirecta; requiere análisis adicional.
R – Relevante	¿Clave para objetivos de cultura de seguridad?	5	Muy ligada a políticas nacionales y sectoriales.[web:35] [web:41]
A – Accionable	¿Informa acciones?	4	Permite reforzar campañas, ajustar contenidos, segmentar perfiles.
G – Genuino	¿Difícil de manipular?	3	Riesgo de “clic mecánico” en e-learning; mitigable con tests.
M – Significativo	¿Entendible para dirección?	4	Sencilla: porcentaje de plantilla que recibe formación.
A – Preciso	¿Fiable?	4	Fácil de controlar mediante plataformas LMS.
T – Oportuno	¿Disponible cuando se necesita?	4	Actualizable en ciclos trimestrales o anuales.
I – Independiente	¿No depende de solo una fuente personal?	4	Datos de sistemas de formación.
C – Rentable	¿Coste asumible de medición?	5	Casi gratuito si se usan herramientas estándar.

Puntuación media: 4,0 → Métrica muy recomendable.

2.3. Métrica M1.1.3 – % de contratos críticos con cláusulas de ciberseguridad

Criterio PRAGMATIC	Pregunta guía	Puntuación	Comentarios
P – Predictivo	¿Predice riesgo futuro en cadena de suministro?	4	Mayor cobertura contractual suele correlacionar con menor exposición.
R – Relevante	¿Clave para objetivos de cumplimiento y GCI Legal?	5	Directamente ligada a pilar Legal y gestión de proveedores.[web:20]
A – Accionable	¿Sugiere acciones concretas?	5	Revisión de contratos, plantillas estándar, formación en compras.
G – Genuino	¿Difícil de maquillar?	3	Requiere muestreo y revisión real de contratos, no solo “checklist”.
M – Significativo	¿Comprensible para negocio y legal?	4	Fácil de explicar y contextualizar.
A – Preciso	¿Medible con exactitud?	3	Depende de una buena clasificación de “contrato crítico”.
T – Oportuno	¿Se puede actualizar regularmente?	3	Normalmente revisión anual o por campañas; no es métrica diaria.
I – Independiente	¿Independiente de sesgos individuales?	3	Depende de cómo se definan criterios de criticidad.
C – Rentable	¿Coste razonable?	3	Requiere análisis documental, pero puede muestrearse.

Puntuación media: 3,6 – Métrica útil, ideal en combinación con indicadores de control real de proveedores.

2.4. Métrica M3.1.2 – N° de sesiones de consejo con reporte de ciberseguridad / año

Criterio PRAGMATIC	Pregunta guía	Puntuación	Comentarios
P – Predictivo	¿Predice futura priorización estratégica?	3	Más un indicador de atención que de futuro rendimiento.
R – Relevante	¿Clave para gobernanza (GCI Org, NIS2)?	5	Muy alineado con tendencias de supervisión directiva. [web:20][web:40]
A – Accionable	¿Sugiere acciones?	4	Se puede fijar objetivo mínimo anual, ajustar agenda del consejo.
G – Genuino	¿Difícil de manipular?	4	Actas y agendas son trazables.
M – Significativo	¿Comprensible?	4	Muy simple: ¿cuántas veces se habla seriamente del tema?
A – Preciso	¿Fiable?	5	Basado en registros formales.
T – Oportuno	¿Oportuno?	3	Métrica anual/trimestral, suficiente para gobernanza.
I – Independiente	¿Independiente?	4	Menos sujeto a interpretación.
C – Rentable	¿Coste?	5	Muy bajo.

Puntuación media: 4,1 → Métrica estratégica muy recomendable.

2.5. Métrica M5.1.2 – N° de notificaciones de incidentes relevantes a CSIRT / autoridades / redes sectoriales

Criterio PRAGMATIC	Pregunta guía	Puntuación	Comentarios
P – Predictivo	¿Ayuda a anticipar tendencias sectoriales?	4	Combinada con otras fuentes, sí; útil para análisis macro. [web:20]
R – Relevante	¿Relevante para cooperación y GCI Cooperation?	5	Muy alineado con objetivos de cooperación nacional/internacional.
A – Accionable	¿Sugiere acciones?	3	Hay que contextualizar: más notificaciones puede ser bueno o malo.
G – Genuino	¿Fácil de manipular?	2	Incentivos a notificar menos; puede requerir validación externa.
M – Significativo	¿Comprensible?	3	Necesita narrativa (no es “más alto = mejor/peor” de forma obvia).
A – Preciso	¿Preciso?	3	Depende de definiciones de “relevante” y registro de casos.
T – Oportuno	¿Oportuno?	4	Se puede reportar mensualmente o trimestralmente.
I – Independiente	¿Independiente?	3	Depende de cultura de reporte.
C – Rentable	¿Coste?	4	Razonable, si se integra en gestión de incidentes.

Puntuación media: 3,4 → Métrica útil si se interpreta con cuidado y se acompaña de otros indicadores.

3. Plantilla genérica PRAGMATIC por métrica

Se recomienda usar la siguiente plantilla para cualquier métrica nueva:

Métrica MX.Y.Z - [Nombre de la métrica]

Descripción: [definición operativa clara].

Criterio	Pregunta guía	Puntuación (1-5)
Comentarios		
P	¿En qué medida es predictiva?	
R	¿En qué medida es relevante para nuestros objetivos?	
A	¿Hasta qué punto es accionable?	
G	¿Cuán genuina es (difícil de manipular)?	
M	¿Es significativa (entendible)?	
A	¿Es precisa?	
T	¿Es oportuna?	
I	¿Es independiente?	
C	¿Es rentable?	

Puntuación media / total: ...

Esta matriz puede formar parte de un taller con responsables de negocio, CISO y analistas, para consensuar qué métricas se adoptan en el cuadro de mando GCI-IGM.